Vulnerability Assessment Report

Cyber Security Internship Program

-Future Interns

Conducted by : vikram singh

Date of Assessment : March 2026
Project Code : FUTURE_CS_01

Table of contents

1. Introduction & Executive Summary ..... Page 3

2. Scope of Assessment ..... Page 4
   - Details of the target URL, IP address, and testing boundaries.

3. Tools & Methodology..... Page 5
   - Description of Nmap, OWASP ZAP, and Browser DevTools.

4. Network Reconnaissance (Nmap Results) ..... Page 6
   - Analysis of open ports and active services.

5. Vulnerability Findings & Remediation ..... Page 8
   - 5.1 Automated Scan Summary (OWASP ZAP).
   - 5.2 Detailed Finding: Missing Security Headers.
   - 5.3 Manual Analysis: Browser DevTools Inspection.

6. Conclusion ..... Page 11
   - Project Conclusion and Final Security Posture.

2. Scope of Assessment :

Target Information:

- Domain: testphp.vulnweb.com
- Resolved IP: 44.228.249.3

Assessment Boundaries:

This assessment focused exclusively on the external-facing services of the target application. The audit was conducted using a Black-Box methodology, utilizing Nmap for network reconnaissance and OWASP ZAP for passive scanning.

To maintain system stability, the following constraints were strictly followed:

No Exploitation: Vulnerabilities were identified but not exploited.

No DoS: Techniques that could disrupt service availability were excluded.

Non-Intrusive: Only authorized, non-destructive scanning tools were utilized.

3. Tools & Methodology:

This assessment followed a standard three-stage process to identify security gaps on the target application.

A. Security Tools Used:

- Nmap (Network Mapper): Used for port scanning and service discovery to map the server's external attack surface.
- OWASP ZAP (Zed Attack Proxy): An automated vulnerability scanner used to find common web security issues like missing headers and cookie risks.
- Browser DevTools: Used for manual inspection of HTTP response headers and real-time cookie verification.

B. Methodology:

- Reconnaissance: Performed a network scan to identify active services and open ports.
- Automated Scanning: Ran a passive vulnerability scan to detect misconfigurations without disrupting the live site.
- Manual Verification: Manually inspected the findings using browser tools to confirm the existence of security gaps.

4. Network Reconnaissance (Nmap Results) :

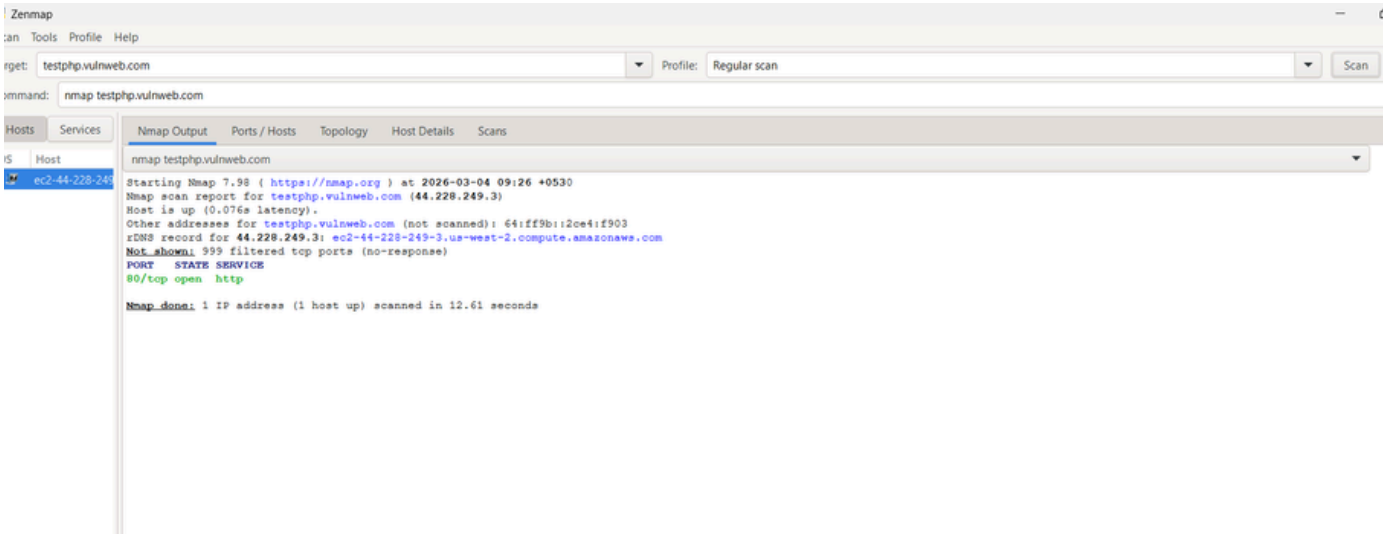
This section details the initial phase of the assessment: identifying the "front doors" of the server to understand what services are accessible to the public.

A. Scan Objective:

The primary goal of this scan was to identify open ports and the services running on them to map the server's attack surface. .

B. Scan Execution:

Target: testphp.vulnweb.com
Target IP :44.228.249.3
Objective: Identify open ports and active services to find potential entry points.



"Figure 1: Terminal output of the Nmap service discovery scan."

C .Network Scan Results:

A scan was conducted to identify active services and potential entry points. The results are summarized below:

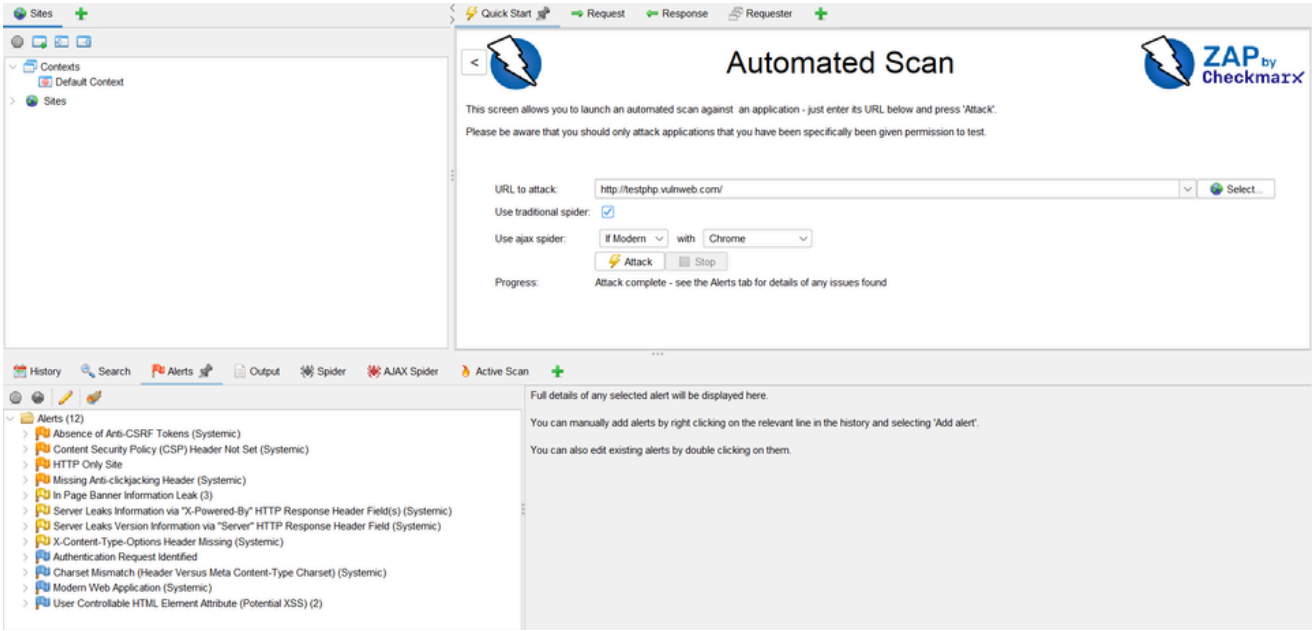
- Total Ports Scanned: 1,000
- Filtered Ports: 999 (No response from the server)
- Open Ports Identified: 1
  - Port 80 (HTTP): Open – Standard web service.

Conclusion:

The scan confirms that only Port 80 (HTTP) is open and accessible. All other 999 scanned ports are filtered, indicating a firewall is in place to block unauthorized access to the server.

5. Vulnerability Findings & Remediation :

5.1 Automated Scan Summary (OWASP ZAP):



"Figure 2: Vulnerability Alert Distribution."

Objective: To perform a comprehensive, non-intrusive vulnerability scan of the target web application's structure and services.

Scan Tool: OWASP ZAP (Zed Attack Proxy) version 2.17.0.
Vulnerability Overview: The automated scan identified a total of 12 security alerts

Risk Distribution:

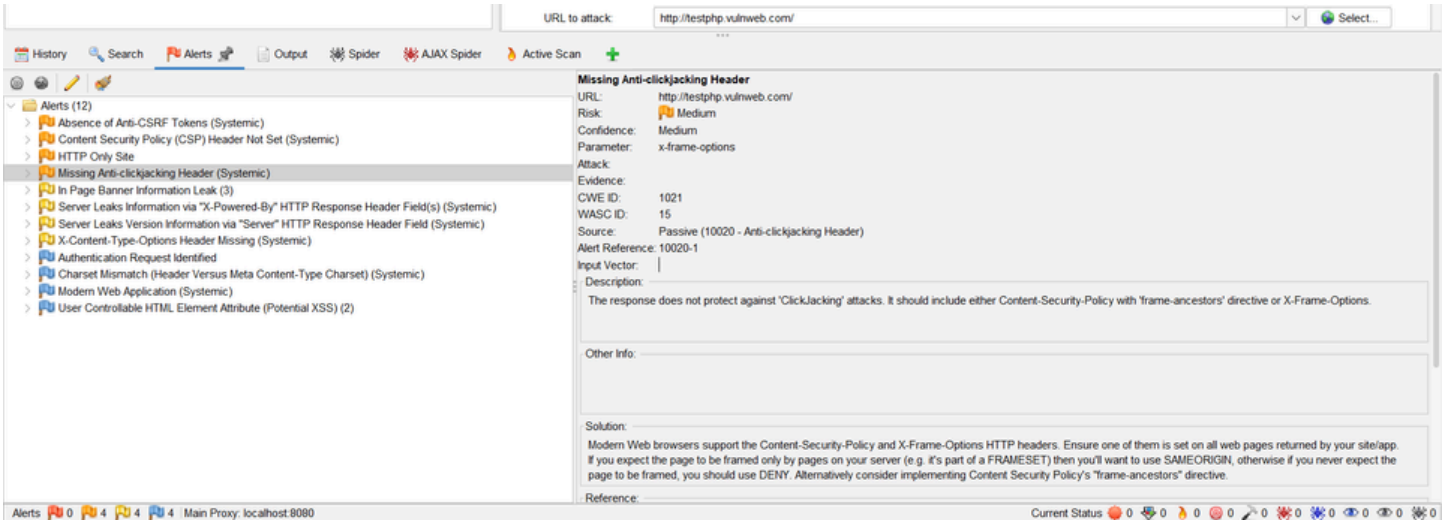
- Medium Risk: 4 Alerts (Orange flags)
- Low Risk: 4 Alerts (Yellow flags)
- Informational: 4 Alerts (Blue flags)

Summary:

The automated scan confirmed that while the network perimeter is restricted, the web application layer contains several configuration gaps, primarily related to missing security headers and session management.

5.2 Detailed Finding: Missing Security Headers:

Vulnerability : Missing Anti-clickjacking Header (X-Frame-Options).
Risk Level: Medium



:Figure 3: Technical Evidence of X-Frame-Options Vulnerability."

Impact:

Without this protection, an attacker can load the legitimate website into a transparent layer over their own malicious domain. This leads to Clickjacking, where the user believes they are interacting with the attacker's visible overlay, but they are actually clicking hidden elements on the target site.

Recommendation:

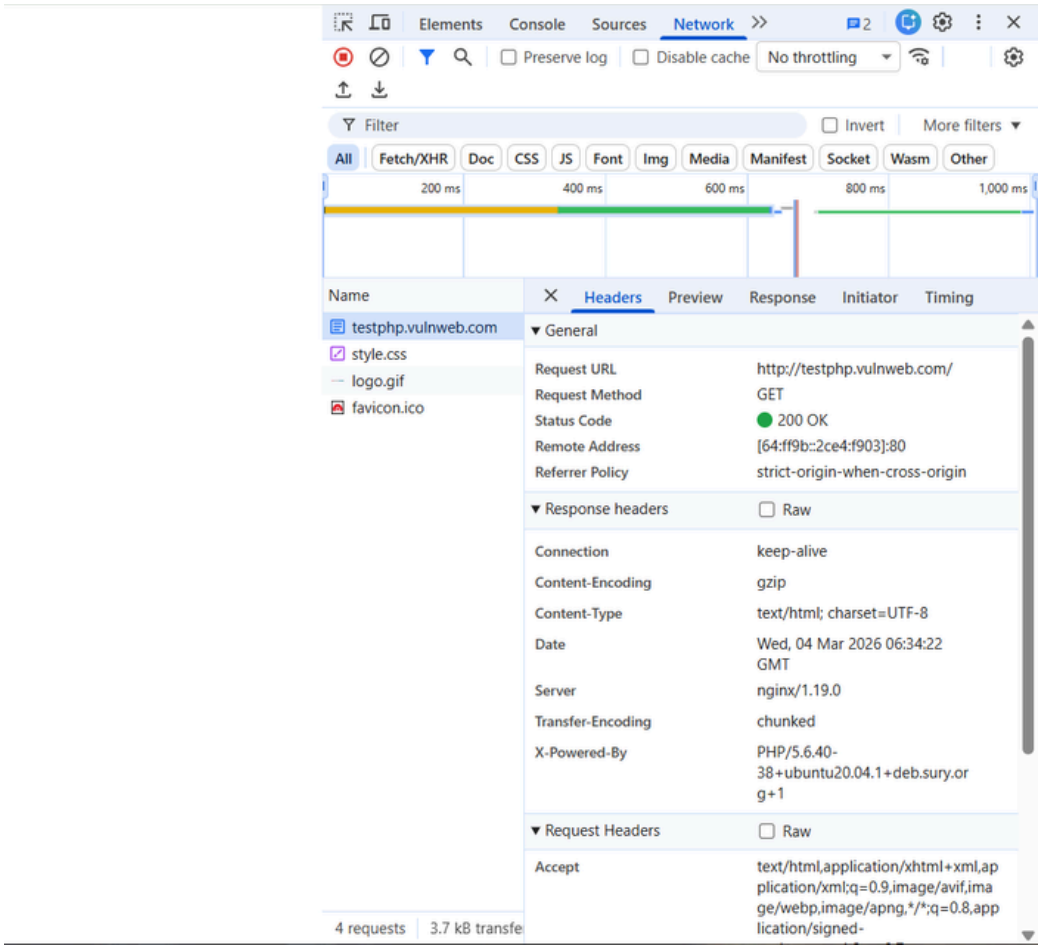
To fix this, the web server must be updated to include the X-Frame-Options security header in its responses . By setting this header to "DENY" or " SAMEORIGIN", the browser is instructed to block the website from being loaded inside an invisible frame on any malicious site . This change effectively stops Clickjacking by ensuring the site only opens in a secure , top-level window.

5.3 Manual Analysis: Browser DevTools Inspection:

Vulnerability : Sensitive Information Disclosure.

Risk Level: Low

A manual inspection was conducted using the browser's Network DevTools to verify the live server responses from testphp.vulnweb.com. During this process, we examined the HTTP Response Headers and the Cookie storage to identify any configuration weaknesses that the automated scan might have flagged .



"Figure 4: Browser DevTools Evidence."

Findings:

- System Version Leaks: The inspection found that the website openly shares the exact versions of its software: nginx/1.19.0 and PHP/5.6.40.
- Unprotected Cookies: We found that the session cookie (testphp.vulnweb.com) is missing the HttpOnly security flag. This means the cookie can be accessed by scripts, which is a security risk.

Impact:

Sharing exact software versions like nginx/1.19.0 and PHP/5.6.40 makes it much easier for hackers to find and use specific, ready-made attacks against the site. Additionally, because the session cookies lack the 'HttpOnly' security flag , they are unprotected. This means an attacker could use a Cross-Site Scripting (XSS) attack to steal a user' s login session and take over their account without needing a password.

Remediation:

To fix these gaps, the server should be updated to hide its software versions by disabling server_tokens in Nginx and expose_php in the PHP settings . Furthermore , the developers must add the ' HttpOnly' flag to all session cookies to protect them from Cross-Site scrip -ting (XSS) attacks . This enusres techincal details are kept private and user sessions remain secure.

6 . Conclusion:

The vulnerability assessment of testphp.vulnweb.com successfully identified key security gaps that could lead to unauthorized actions or data theft. While the network itself is stable , the web application remains vulnerable to Clickjacking and Information Disclosure due to mi -issing security headers and uprotected cookies.By addressing these configuration issue,the application can significantly improve its defense against common threats like Cross-site-Scripting (XSS).

Prioritized Remediation List:

- Immediate: Implement the X-Frame-Options header to block Clickjacking attacks.
- High Priority: Update session cookies with the HttpOnly flag to prevent session hijacking via XSS.
- Standard: Disable server version broadcasting (Nginx and PHP) to reduce the success rate of targeted exploits.